

Full Social Media EPSS Analysis Explanation

Plain-language explanation of the dataset, features, methods, figures, tables, results, and findings.

1. Purpose

This project studies social-media posts about CVEs. The goal is to understand whether social-media activity can help predict future exploitation risk. EPSS is the main risk signal, and CISA KEV is used as an external known-exploitation label.

The analysis is framed as early warning and prediction, not as proof that social media causes exploitation.

2. Dataset Overview

- Three files were analyzed: Gemma, GPT, and Mistral summary variants.
- Each file has 9,218 rows and 28 columns.
- The static CVE and post metadata are the same across files; the LLM summaries differ.
- The row grain is one social-media post linked to one CVE.
- Telegram is excluded from temporal work because its dates are not true publication dates.

Item	Value
Rows per model file	9,218
Canonical/base CVEs	5,692
Non-Telegram rows	6,628
First non-Telegram CVE events	4,187
Telegram rows excluded from temporal work	2,590

3. Important Attributes

Field	Easy meaning
source	Platform/source of the post
date_posted	Post date, except Telegram is not reliable for timing
social_media_post	Original post text
epss_score	Exploitation probability estimate
cvss_score	Technical severity score
CVSS submetrics	Attack vector, complexity, privileges, user interaction, scope, impacts
source_links / github_urls	External evidence and GitHub links
LLM summaries	Generated summaries from Gemma, GPT, and Mistral

4. Platform Profile

Platforms are not interchangeable. Some sources focus on new CVEs, while others include older or already-visible CVEs.

source	posts	unique_cves	mean_epss	median_epss	mean_cvss	pct_enriched	first_post	last_post
BleepingComputer	755	276	0.19062	0.00228	8.1415	20.132	2025-01-04	2025-05-30
ExploitDB	588	362	0.1804	0.00146	7.7721	12.585	2023-05-02	2025-05-29
HackerNews	816	483	0.25256	0.00738	7.7561	4.6569	2025-04-07	2025-05-28
Mastodon	3136	2860	0.00859	0.00043	8.8121	58.578	2024-09-04	2025-05-20
Reddit	1333	616	0.1495	0.00174	7.9374	5.7764	2021-11-23	2025-06-01
Telegram	2590	1845	0.11614	0.00885	7.6851	32.432	2022-05-05	2025-06-01

5. Figures and What They Mean

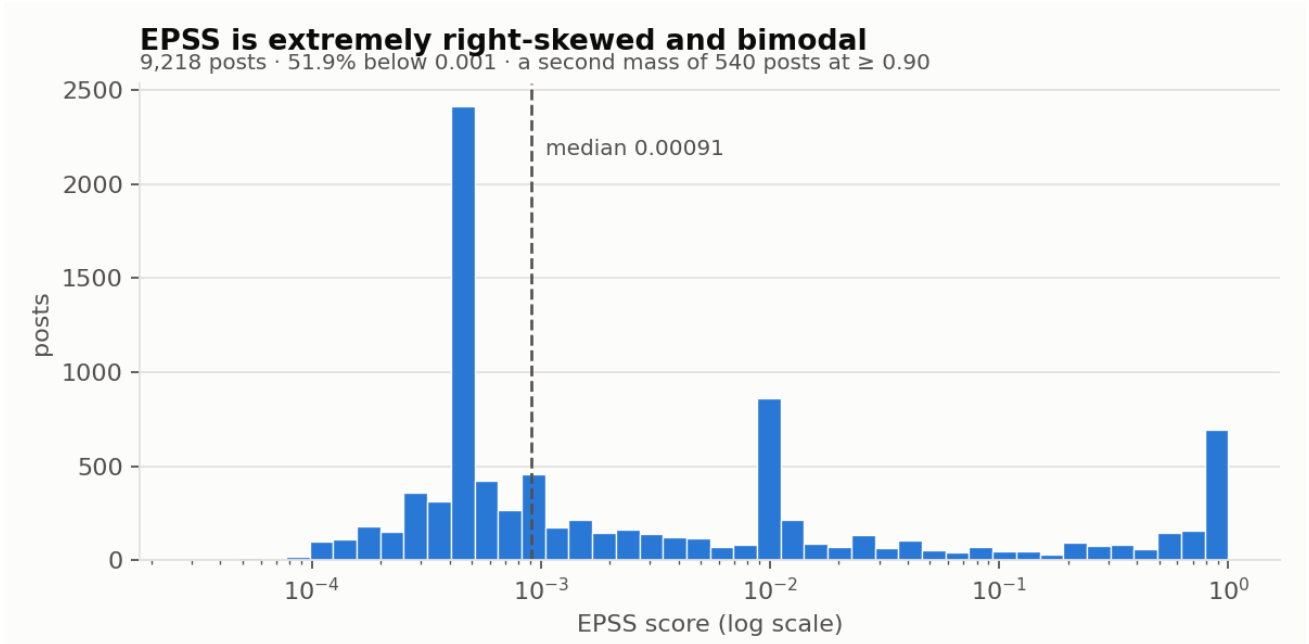


Figure 1. EPSS distribution. Most CVEs have very small EPSS values, while a smaller group has very high EPSS. This is why raw EPSS is hard to model directly.

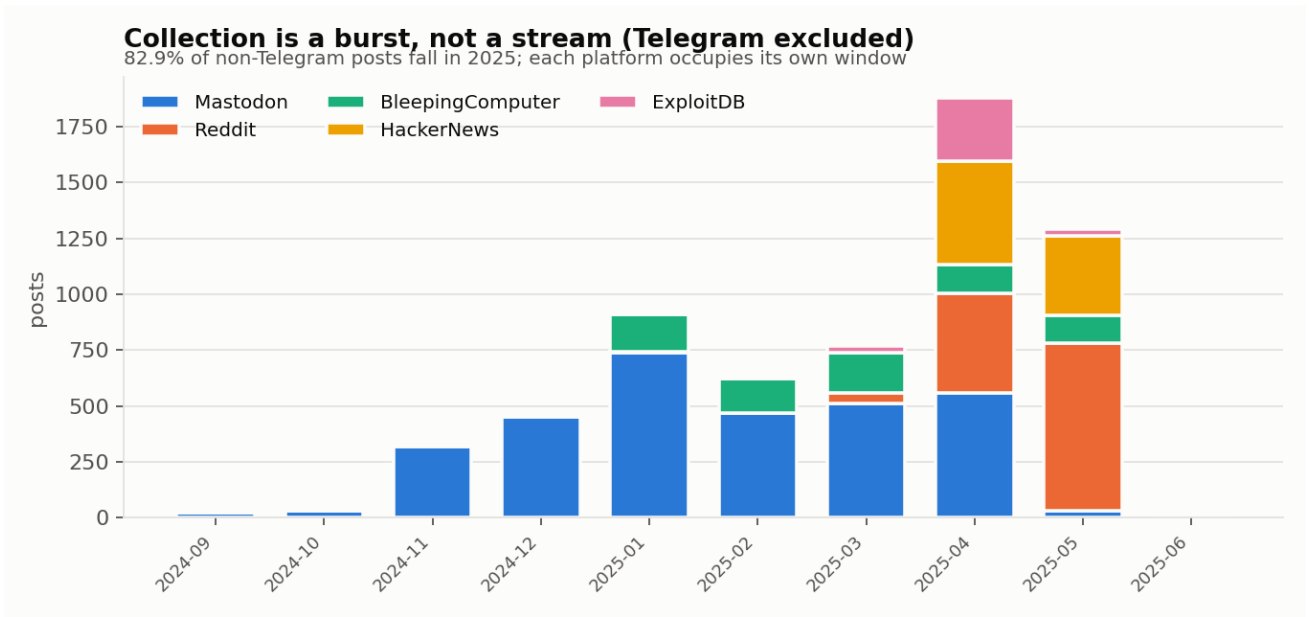


Figure 2. Monthly post volume by platform, excluding Telegram. The dataset is bursty and platform coverage changes over time.

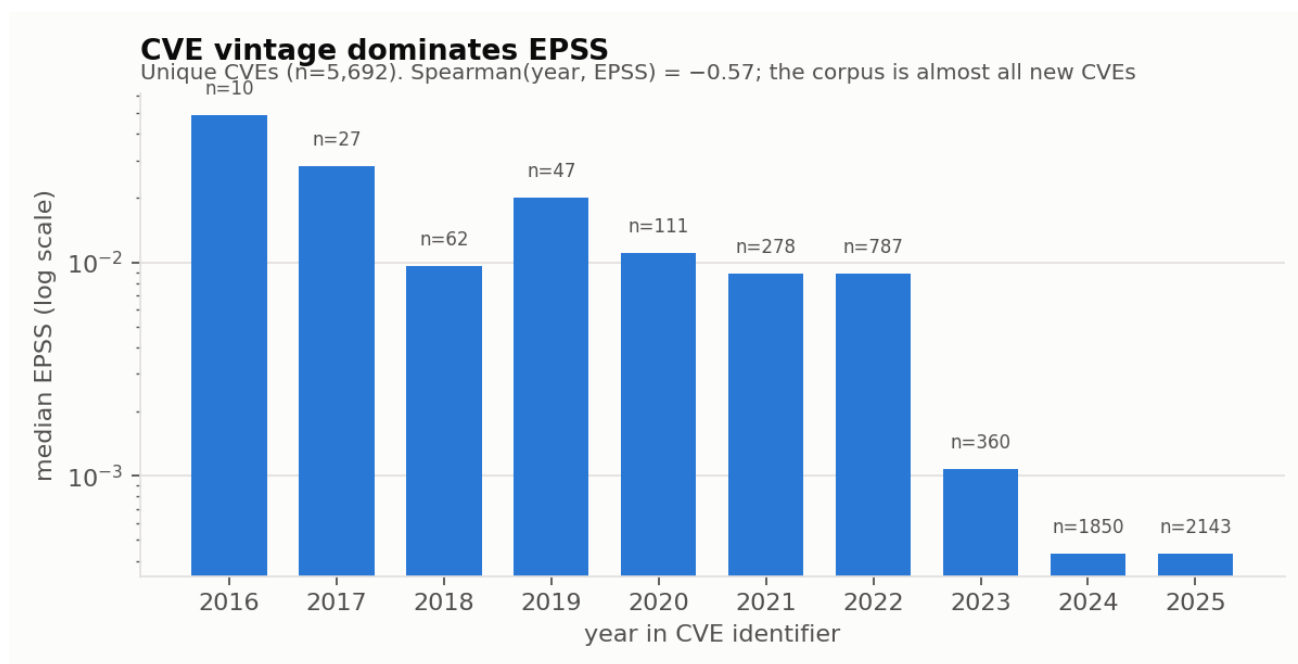


Figure 3. EPSS by CVE year. Older CVEs often have higher EPSS because there has been more time for exploitation evidence to appear.

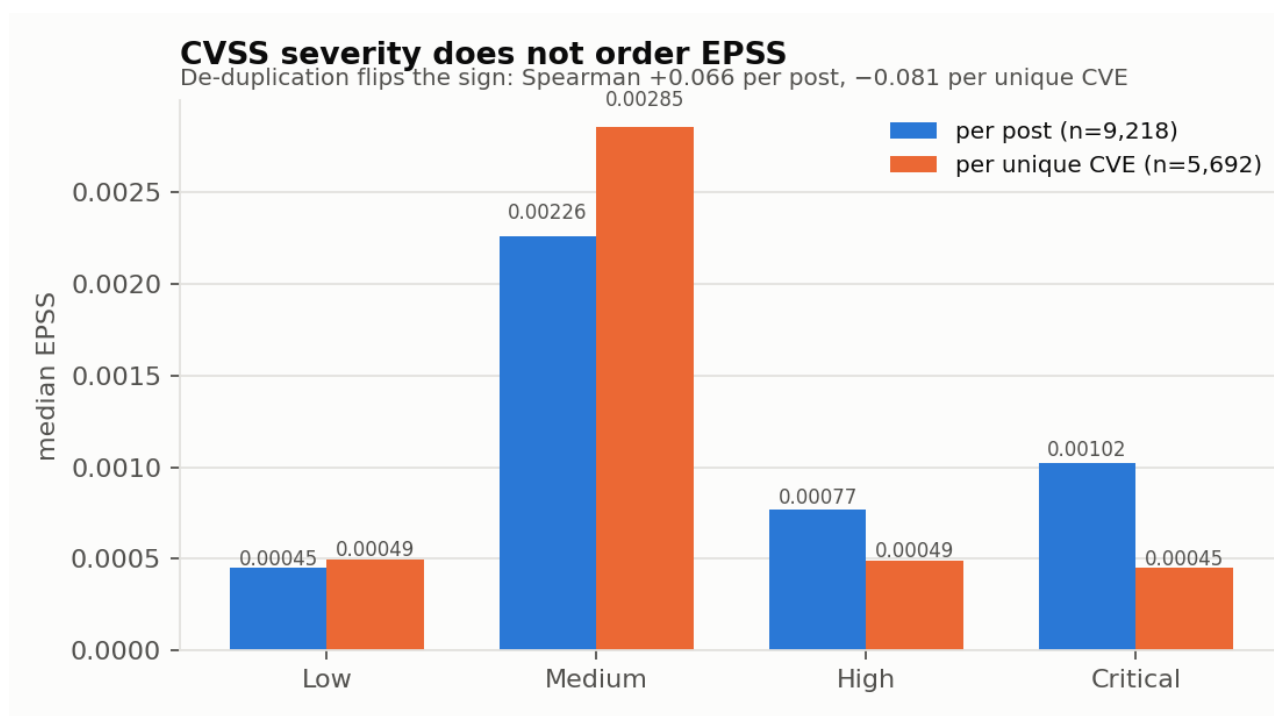


Figure 4. CVSS versus EPSS. CVSS and EPSS are different. CVSS measures severity; EPSS measures exploitation likelihood.

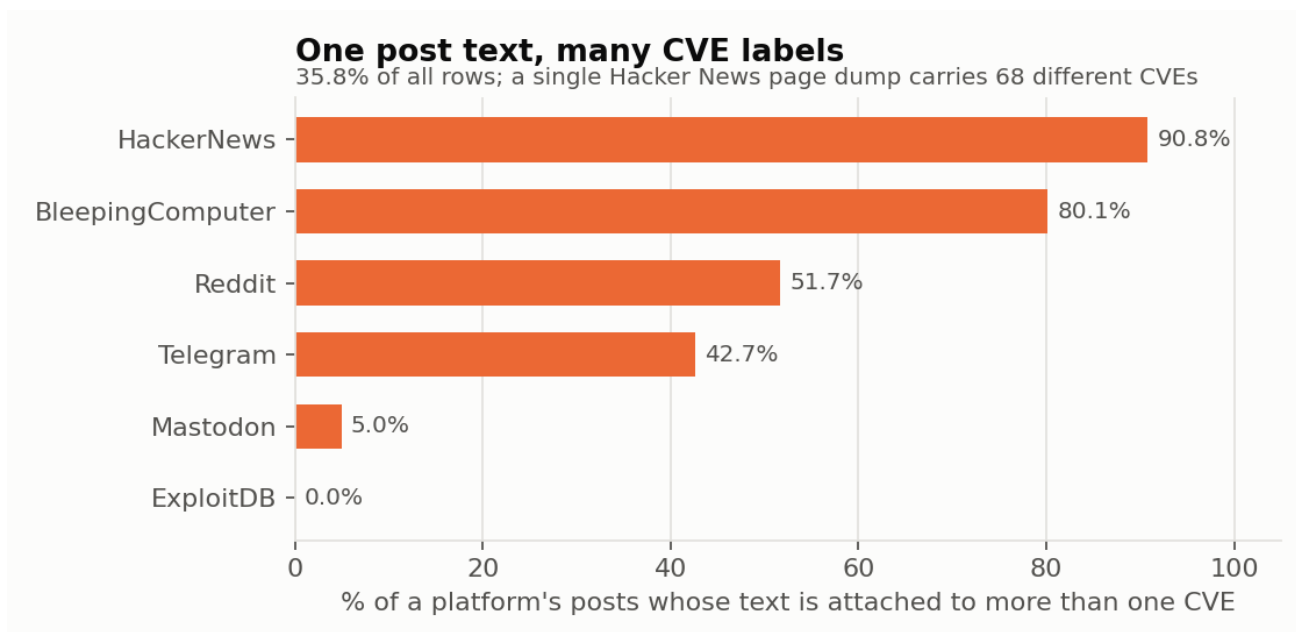


Figure 5. Post text reuse. Some identical text is attached to many CVEs, which creates contamination risk for text modeling.

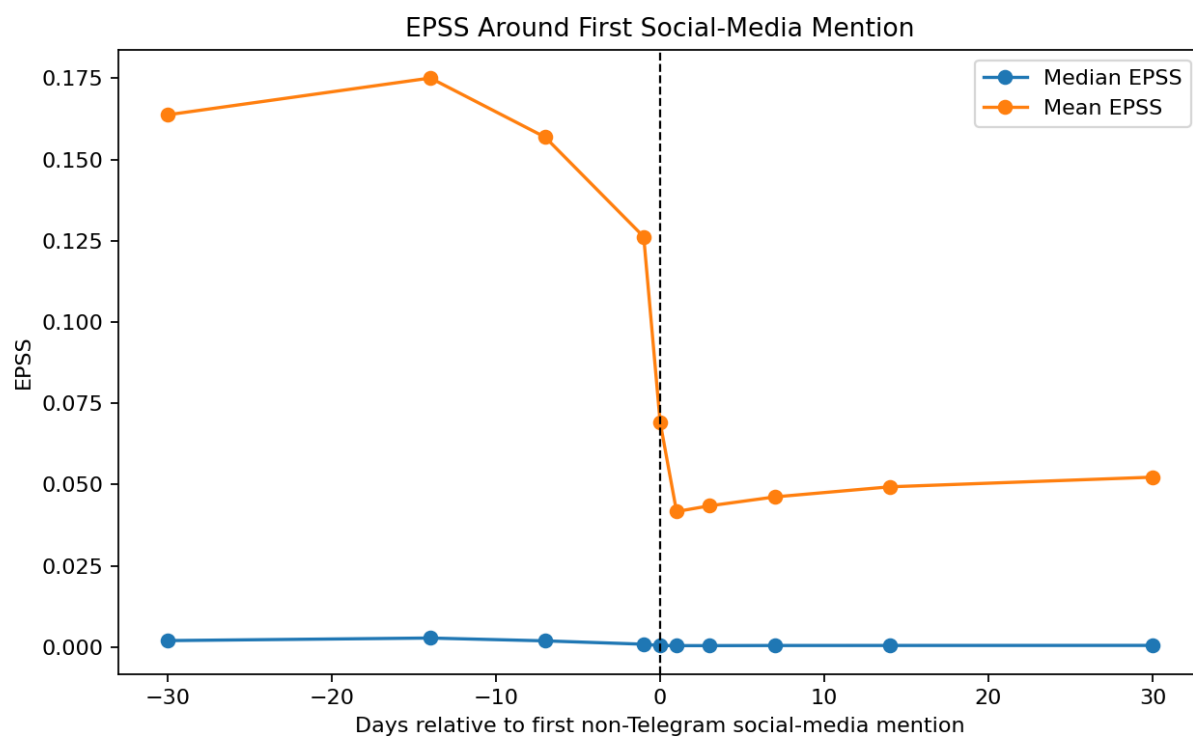


Figure 6. EPSS around first social-media mention. This shows how EPSS changes before and after the first non-Telegram mention of a CVE.

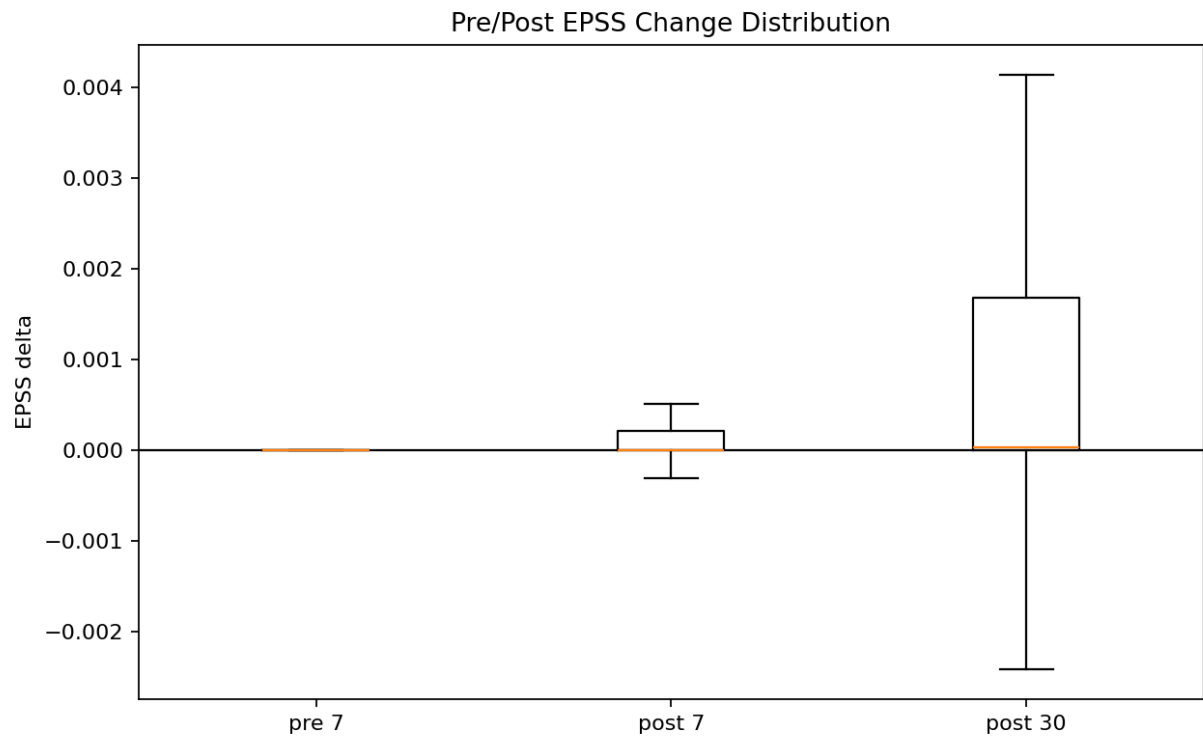


Figure 7. EPSS delta distribution. This compares pre-event and post-event EPSS changes. The distribution is skewed, so medians and direction counts matter.

6. Data Quality Findings

- Telegram dates are crafting dates, so Telegram is excluded from temporal analysis.
- HackerNews rows often look like full page scrapes, not simple individual posts.
- Many rows share the same post text across different CVEs, which can contaminate text models.
- CVE age strongly affects EPSS, so CVE year must be controlled or matched.
- CVSS and EPSS are different: severity is not the same as exploitation probability.
- LLM summaries are useful, but they can include model-specific formatting, omissions, or hallucinations.

7. EPSS by CVE Year

Older CVEs often have higher EPSS because there has been more time for exploitation evidence to accumulate.

cve_year	count	mean	median
2006	1	0.86871	0.86871
2008	1	0.04015	0.04015
2009	1	0.93821	0.93821
2010	2	0.70186	0.70186
2012	1	0.0138	0.0138
2013	4	0.40952	0.49027
2014	3	0.8851	0.94237
2015	4	0.01117	0.00724
2016	10	0.35259	0.04868
2017	27	0.39858	0.02808
2018	62	0.16903	0.00961
2019	47	0.27117	0.02011
2020	111	0.1252	0.01108
2021	278	0.11076	0.00885
2022	787	0.03518	0.00885
2023	360	0.12443	0.00107
2024	1850	0.03441	0.00043
2025	2143	0.00213	0.00043

8. Monthly Volume, Excluding Telegram

The dataset is bursty. Platform coverage changes over time, so a chronological split can accidentally become a platform split.

date	BleepingComputer	ExploitDB	HackerNews	Mastodon	Reddit
2021-11	0	0	0	0	1
2021-12	0	0	0	0	6
2022-01	0	0	0	0	2
2022-11	0	0	0	0	2
2023-01	0	0	0	0	6
2023-02	0	0	0	0	6
2023-03	0	0	0	0	5
2023-04	0	0	0	0	5
2023-05	0	41	0	0	13
2023-06	0	23	0	0	0
2023-07	0	30	0	0	3
2023-08	0	25	0	0	0
2023-09	0	11	0	0	0
2023-10	0	8	0	0	0
2023-11	0	0	0	0	1
2024-02	0	10	0	0	0
2024-03	0	42	0	0	2
2024-04	0	36	0	0	3
2024-05	0	8	0	0	0
2024-06	0	4	0	0	2
2024-07	0	0	0	0	1
2024-08	0	2	0	0	1
2024-09	0	0	0	21	1
2024-10	0	2	0	32	1
2024-11	0	0	0	320	5
2024-12	0	0	0	450	5
2025-01	168	0	0	741	3
2025-02	154	0	0	469	1
2025-03	178	30	0	510	51
2025-04	130	284	462	560	443
2025-05	125	32	354	33	750
2025-06	0	0	0	0	14

9. Analysis Flow

- Inventory and verification: checked rows, columns, missing values, duplicate structure, and file consistency.
- Feature analysis: studied EPSS, CVSS, platform behavior, text length, GitHub evidence, and source-link evidence.
- LLM summary analysis: checked coverage, faithfulness, length, formatting, and hallucination risk.
- Temporal EPSS analysis: used first non-Telegram post date as the event date and pulled historical EPSS.
- Temporal feasibility audit: showed that a broad two-sided before/after event study is not reliable for the whole corpus.
- Forward matched study: compared first-mentioned CVEs against similar not-yet-mentioned controls.

10. Temporal EPSS Results

EPSS often moves after the first social-media mention, but many CVEs do not have enough pre-event EPSS history. That is why the final design became forward-looking rather than causal before/after.

metric	n	mean	median	p25	p75	increased	decreased	unchanged	increase_pct	decrease_pct	ttest_p	wilcoxon_p_nonzero
epss_delta_pre_7	924	0.0059892	0	0	0	198	83	643	21.43	8.98	0.025298	3.1442e-06
epss_delta_pre_7_to_anchor	935	0.010968	0	0	1e-05	235	89	611	25.13	9.52	0.00055532	1.7022e-09
epss_delta_anchor_to_plus_7	4092	0.0066415	0	0	0.0001	1492	351	2249	36.46	8.58	8.76e-12	1.4583e-123
epss_delta_anchor_to_plus_30	4088	0.013006	0	0	0.00027	2033	550	1505	49.73	13.45	6.4286e-20	4.6796e-154
epss_anchor_post_minus_pre_7	916	0.0057785	0	-5e-05	0.0005725	302	266	348	32.97	29.04	0.13543	2.7067e-05
epss_anchor_post_minus_pre_30	778	-0.0096739	2.5e-05	-0.001355	0.0022675	396	292	90	50.9	37.53	0.16756	0.027486

11. Forward-Looking Matched Study

The final study asks whether a CVE rises more than comparable controls after first social-media mention. Controls are CVEs from the same corpus whose first mention happens after the treated CVE's +30 day window.

- Matched on CVE year, CVSS severity/static profile, and baseline EPSS percentile.
- Used a baseline percentile caliper of 0.10.
- Used EPSS percentile because it is more stable across EPSS model changes.

12. Unmatched Forward EPSS Movement

horizon_days	events_with_outcome	mean_percentile_delta	median_percentile_delta	increase_pct	decrease_pct	unchanged_pct
7	4092	0.04299	0.00125	81.92	17.38	0.71
30	4088	0.060727	0.00612	83.93	15.85	0.22

Before controls, most CVEs increase after first social-media mention. This is useful, but not enough by itself because similar CVEs may also rise.

13. Matched Control Results

horizon_days	matched_events	mean_att_percentile_delta	median_att_percentile_delta	p25	p75	treated_gt_control_pct	treated_lt_control_pct	ttest_p	wilcoxon_p_nzero
7	869	0.045343	4.6667e-05	-0.00033	0.0321	53.51	43.84	4.9826e-13	4.0691e-09
30	868	0.0017783	2e-05	-0.031222	0.04571	50.58	48.04	0.83248	0.4811

After matching, the +7 day signal remains. The +30 day signal is much weaker. This means social media is better supported as a short-term warning signal.

14. CISA KEV Enrichment

metric	value	pct
events	4187	100
kev_ever	284	6.78
kev_after_event	119	2.84
kev_within_90d	102	2.44

KEV gives an external known-exploitation label. It is rare but valuable because it is not just another EPSS score.

15. Predictive Feature Ablation

The ablation checks whether additional features improve prediction. CVSS alone is weaker. Baseline EPSS helps. Platform and attention features help further.

outcome	feature_set	n	positive_rate	roc_auc_mean	roc_auc_std	pr_auc_mean	pr_auc_std
percentile_increase_plus7	cvss_only	4116	0.81438	0.57703	0.018383	0.84318	0.010889
percentile_increase_plus7	cvss_plus_baseline_epss	4116	0.81438	0.66141	0.014423	0.889	0.0084572
percentile_increase_plus7	plus_platform_attention	4116	0.81438	0.71239	0.0089329	0.90468	0.0058811
percentile_increase_plus30	cvss_only	4116	0.83358	0.60981	0.010586	0.87213	0.0010864
percentile_increase_plus30	cvss_plus_baseline_epss	4116	0.83358	0.71257	0.014979	0.92001	0.0062109
percentile_increase_plus30	plus_platform_attention	4116	0.83358	0.74662	0.021445	0.9329	0.0091467
kev_within_90d	cvss_only	4116	0.023567	0.62114	0.056396	0.041009	0.0063279
kev_within_90d	cvss_plus_baseline_epss	4116	0.023567	0.67369	0.061344	0.07912	0.019098
kev_within_90d	plus_platform_attention	4116	0.023567	0.92554	0.035879	0.5236	0.073085

16. Final Findings

- Social-media activity is a useful short-term signal for exploitation-risk movement.
- The best-supported effect is around +7 days after first mention.
- The +30 day matched effect is weak after controls.
- Platform and attention features improve prediction beyond CVSS and baseline EPSS.
- The dataset should be used for prediction and early warning, not direct causal claims.

17. Recommended Improvements

- Build an external control group from NVD/FIRST CVEs not seen in this corpus.
- Clean or separate HackerNews page dumps.
- Remove or down-weight shared-text rows.
- Use CISA KEV as a primary external exploitation target.
- Compare original posts against Gemma, GPT, and filtered Mistral summaries.
- Always split modeling by canonical CVE.

18. Final Conclusion

The final defensible conclusion is: social-media activity is a useful short-term predictive signal for vulnerability exploitation risk, especially when combined with baseline EPSS, CVSS, platform information, and attention features. The correct framing is early warning, not proof of causality.